Insider Lab

1. Scenario

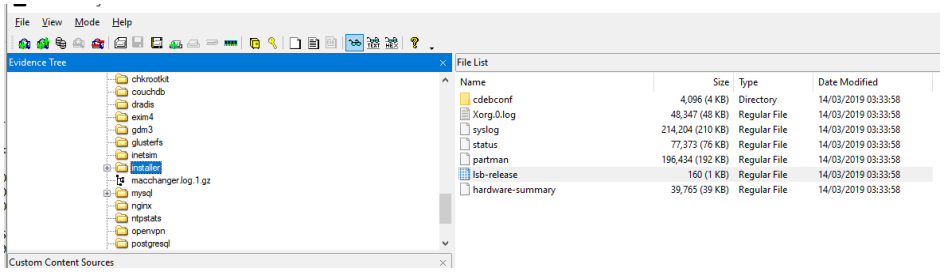
After Karen started working for 'TAAUSAI,' she began doing illegal activities inside the company. 'TAAUSAI' hired you as a soc analyst to kick off an investigation on this case.

You acquired a disk image and found that Karen uses Linux OS on her machine. Analyze the disk image of Karen's computer and answer the provided questions.

2. Write up

1. Which Linux distribution is being used on this machine?

- Ans: Kali
- I use the FTK Imager tool for opening a disk image file
  - The var directory contains data which the system writes during runtime
- The /var/log directory is the most important because it contains system and application logs
- The /var/log/installer directory stores logs of the OS installation process

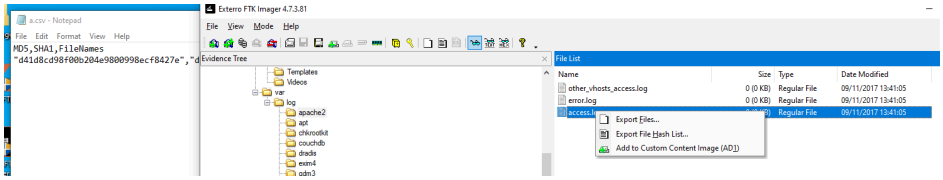


- I found out a file named lsb_release. It contains information about the Linux distribution being used on this machine

```
DISTRIB_ID=Debian
DISTRIB_DESCRIPTION="Kali GNU/Linux installer"
DISTRIB_RELEASE="2017.1 (kali-rolling) - installer build 20171009"
X_INSTALLATION_MEDIUM=cdrom
```

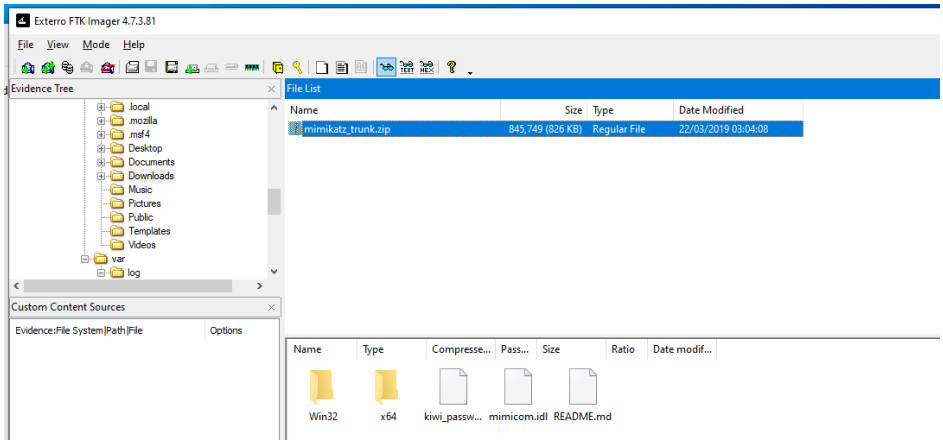
2. What is the MD5 hash of the Apache **access.log** file?

- Ans: d41d8cd98f00b204e9800998ecf8427e
- I choose Export File Hash List… to get MD5, SHA1 of **access.log** file
- The Apache access.log file records all HTTP requests made to the server.
- "**d41d8cd98f00b204e9800998ecf8427e"** hash is MD5 hash of empty file. If an attacker uses the echo "" > access.log command, this file has a newline character (\n) causing the hash to change



3. It is suspected that a credential dumping tool was downloaded. What is the name of the downloaded file?

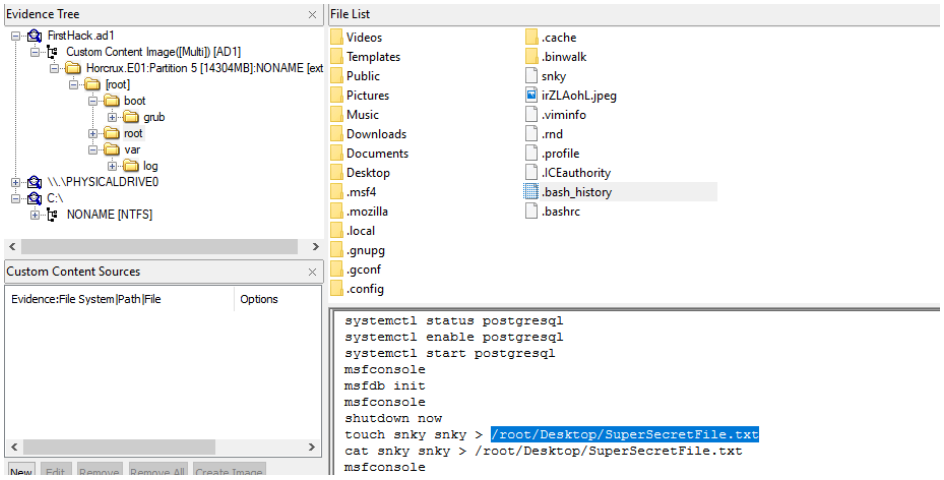
- Ans: mimikatz_trunk.zip
- I look into the Download directory and find out mimikatz_trunk.zip file
    - Mimikatz is a tool designed for Windows to extract credentials such as: password, NTLM hashes, Kerberos tickets from LSASS,…



4. A super-secret file was created. What is the absolute path to this file?

- Ans: /root/Desktop/SuperSecretFile.txt

- A .bash_history file in the /root directory contains commands executing on the terminal
    - I found out a “touch snky snky > /root/Desktop/SuperSecretFile.txt” command. It indicates that a SuperSecretFile.txt file was created

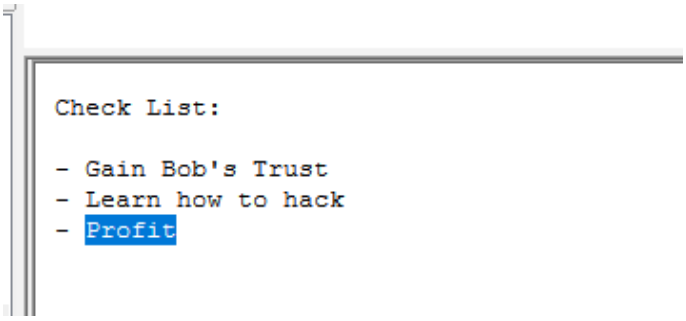


5. What program used the file **didyouthinkwedmakeiteasy.jpg** during its execution?

- Ans: binwalk
- In the .bash_history file, i found out a “binwalk didyouthinkwedmakeiteasy.jpg” command. The binwalk tool can identify and optionally extract files and data that have been embedded inside of other files

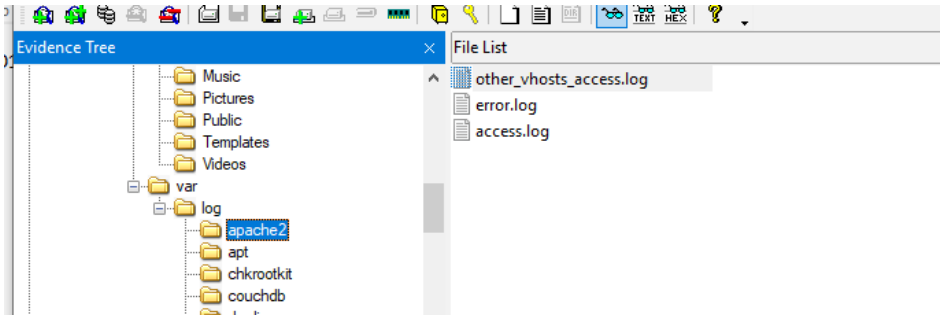
6. What is the third goal from the checklist Karen created?

- Ans: Profit
- I found out a Checklist file in the Desktop directory where contains mimikatz directory



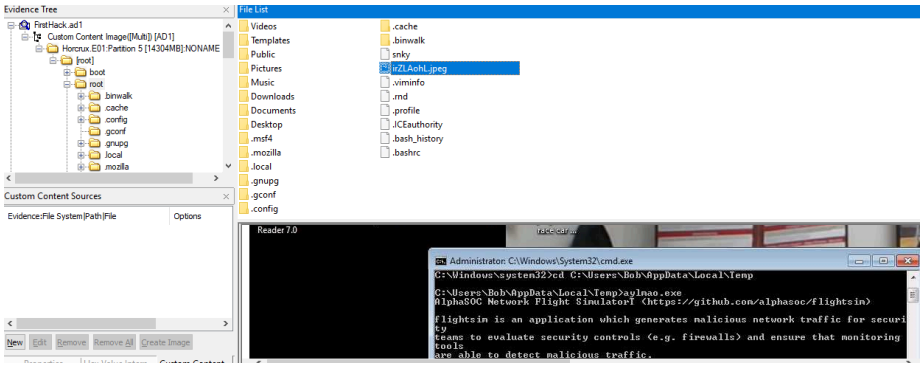
7. How many times was Apache run?

- Ans: 0
- All of files in the /var/log/apache2 directory are empty. Conclusion, Apache has never been run in this system



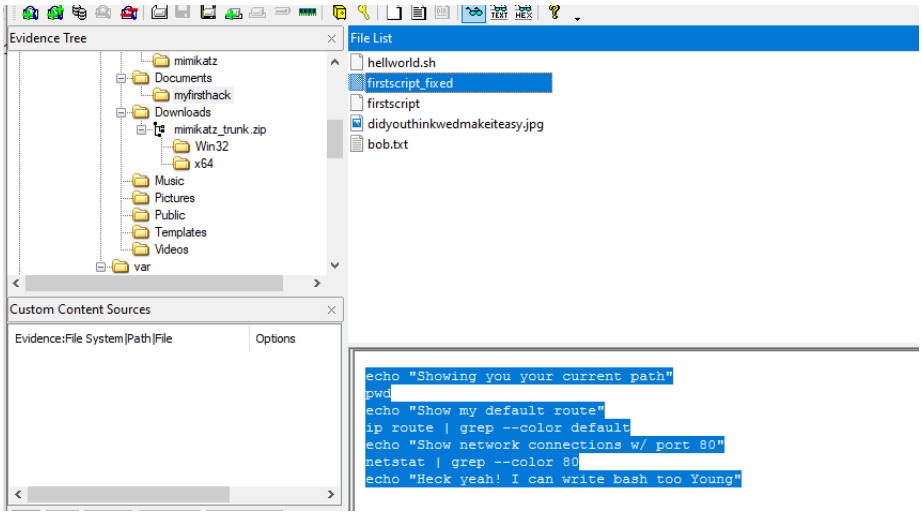
8. This machine was used to launch an attack on another. Which file contains the evidence for this?

- Ans: irZLAohL.jpeg
- In the root folder, i found out a file named irZLAohL.jpeg containing a screenshot of a command prompt. On the cmd, the hacker run cd command to the temp folder of a Bob user and run a suspicious file.
    - The FlightSim tool which is shown in the terminal output used for generating malicious network traffic to simulate attacks.



9. It is believed that Karen was taunting a fellow computer expert through a bash script within the Documents directory. Who was the expert that Karen was taunting?

- Ans: Young
- The firstscript_fixed file in the Documents directory contains a script with some strings and commands. On the last line, hacker used a echo command to print “Heck yeah! I can write bash too Young”. This indicates that Young was the expert that Karen was taunting

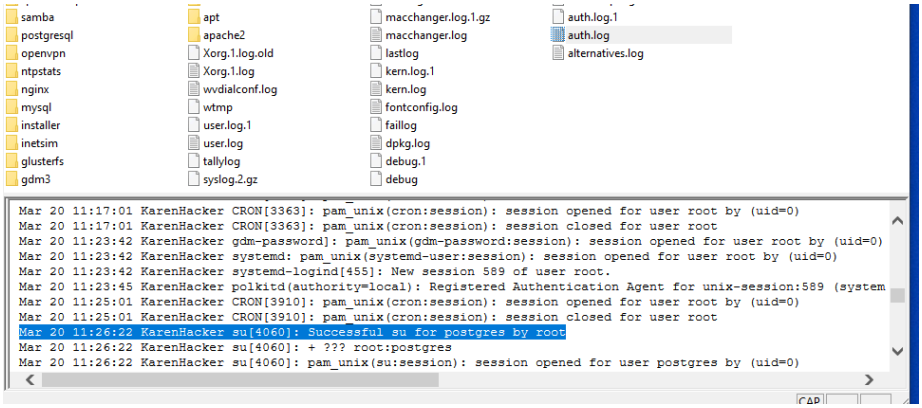


10. A user executed the **su** command to gain root access multiple times at 11:26. Who was the user?

- Ans: postgres
- I find the information in auth.log file. And, I found out a “Mar 20 11:26:22 KarenHacker su[4060]: Successful su for postgres by root” string indicating that the postgres user successfully executed the su command.

- The attacker usually uses RCE vulnerability on PostgresSQL services to gain unauthorized permissions. The attacker finds misconfigured files or files have SUID permission later to privilege escalation to root.

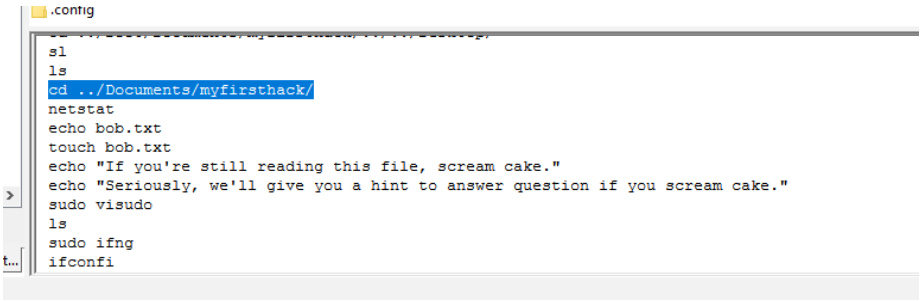
- The auth.log file records authentication-related events such as: logins, privilege escalations, SSH conections,…



11. Based on the bash history, what is the current working directory?

- Ans: /root/Documents/myfirsthack/

- The last cd command is “cd ../Documents/myfirsthack/” so the current working directory is /root/Documents/myfirsthack/ where contains script files



3. Mitre ATTCK

1. Execution

- T1059.004: **Command and Scripting Interpreter: Unix Shell**

  - The insider used Linux system commands on the terminal

2. Credential Access

- T1003: **OS Credential Dumping**
    - The attacker uses mimikatz tool to dump credentials to obtain account login, NTLM hashes, password, Kerberos tickets from LSASS memory